MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D08

Conditional Access Control Design

Deliverable 8 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Conditional Access Control Design

MDM-D08

1. Purpose and Scope

This appendix defines the Conditional Access design for the mobile service. It translates the access requirements in MDM-D05, MDM-D06 and MDM-D07 into four Microsoft Entra Conditional Access policies.

The design covers access to Microsoft 365 from Android and iOS/iPadOS devices. It applies to corporate devices, approved BYOD and Intune administrators.

Windows and macOS devices, guest and external users, and the design of user MFA are out of scope. They depend on enterprise policies, described in Sections 4.5 and 5.

This is a design document. No tenant was configured. Evidence and testing in MDM-D09 and MDM-D10 are simulated.

2. Design Approach and Prerequisites

2.1 Design Approach

Every user is covered by default. Corporate devices must be compliant. Approved BYOD users may also use App Protection. Mobile browsers are blocked. Administrators need phishing-resistant MFA.

User Population	Policy	Access Requirement
Employees and contractors on corporate devices	MDM-CAP-001	Compliant device
Approved BYOD users	MDM-CAP-002	Compliant device or App Protection
Employees not approved for BYOD, on personal devices	MDM-CAP-001	Blocked. A personal device cannot be compliant.
Contractors on personal devices	MDM-CAP-001	Blocked
All users in mobile browsers	MDM-CAP-003	Blocked
Intune administrators	MDM-CAP-004	Phishing-resistant MFA
Guest and external users	None	Outside D06 scope. Enterprise policies apply.

2.2 Groups

Group	Members	Managed By	Used By
MDM-BYOD-Approved	Employees who passed the D07 Section 4.17 activation gate	IT Operations Team	MDM-CAP-002 (include); MDM-CAP-001 (exclude)
MDM-Intune-Admins-*	Accounts holding Intune RBAC roles, one group per role	Separately authorized role administrators (D07 Sections 5.2 and 5.4)	Intune role assignments; MDM-CAP-004 (include)
MDM-Emergency-Access	Emergency access accounts	Enterprise IAM team	Excluded from all four policies

Group names are project-defined. Each addition to MDM-BYOD-Approved must reference its activation record.

2.3 Prerequisites

Field	Details
Licensing	Microsoft Entra ID P1 for all users in scope (D07 Section 2.1).
Corporate Enrollment	Corporate devices are enrolled in Intune (D07 Section 2).
Compliance Policies	Compliance policies are assigned to corporate devices (D07 Section 3.6).
App Protection Policies	Policies follow D07 Section 4 and target unmanaged devices only.
Broker Apps	Microsoft Authenticator on iOS. Company Portal on Android.
iOS App Configuration	OneDrive on corporate iOS receives a manual app configuration policy.
Administrator Methods	Administrators register phishing-resistant methods before MDM-CAP-004 is enforced.
Emergency Access	Emergency accounts are created and tested (Section 4.1).
Policy Administration	The enterprise IAM team holds the Conditional Access Administrator role.

Field	Details
User MFA	The enterprise user MFA policy is confirmed (Section 4.5).

3. Access Policies

3.1 Corporate Mobile Device Compliance

Field	Details
Policy	MDM-CAP-001 - Corporate Mobile - Require Compliant Device
Traceability	MDM-CTL-003; MDM-RSK-003; D06 Section 4; D07 Sections 3.3 to 3.8.
Applies to	All users on Android and iOS, all resources and all client app types. Excluded: the approved BYOD group (covered by MDM-CAP-002), guest and external users, and emergency access accounts (Section 4.1).
Requirement	Access only from devices that Intune reports as compliant.
Design decisions	Devices with no compliance policy count as not compliant and are blocked (D07 Section 3.6). Personal devices of employees not approved for BYOD, and of contractors, cannot be compliant, so they are blocked. Legacy clients are blocked. Enrollment is not blocked, so new devices can enroll before they become compliant. No manual override; restoration follows Section 4.3.
Rollout and ownership	Starts in report-only; switched on after MDM-CTL-004 approval and pilot results. Owner: IT Operations Manager (MDM-CTL-003). Operator: IT Operations Team.
Limitations	Platform spoofing (L-01). Access may continue until the token renews (L-02).
Validation (D10)	Compliant device allowed; noncompliant device, device with no policy and legacy client blocked; new device enrolls; employee and contractor personal devices blocked; access restored after remediation; iPadOS covered by the iOS platform.
Source	Microsoft Learn: Conditional Access grant, conditions and user targeting; require device compliance. Reviewed 3 November 2026.

3.2 BYOD App Protection Access

Field	Details
Policy	MDM-CAP-002 - BYOD Mobile - Require Compliant Device or App Protection
Traceability	MDM-CTL-002; MDM-RSK-002; D06 Section 4; D07 Sections 4.1 and 4.17.
Applies to	The approved BYOD group on Android and iOS, all resources and all client app types. Excluded: emergency access accounts. Users join the group only after the D07 Section 4.17 activation gate; on withdrawal they are removed (effective within a day, Section 4.2). Departures follow D07 Section 5.8 and data removal D07 Section 4.15.
Requirement	A compliant device or an app protected by Intune App Protection; one of the two is enough.
Design decisions	The compliant option exists because a BYOD user may also hold a corporate device, which must then be compliant. App Protection targets unmanaged devices only, so a corporate device cannot pass through the app option. Apps outside the D07 Section 4.1 policies fail the grant. Device-level checks (root, OS, patch, offline, disabled account) are enforced by App Protection in D07 Sections 4.7 to 4.11, not here. A broker app is required (Authenticator on iOS, Company Portal on Android); there is no MDM enrollment. On corporate iOS, OneDrive needs a manual app configuration (Section 2.3). Legacy clients are blocked.
Rollout and ownership	Starts in report-only; a "Report-only: Failure" entry for the app control is not by itself a pilot failure. Switched on after MDM-CTL-004 approval and pilot results. Restoration follows Section 4.3. Owner: IT Operations Manager (MDM-CTL-002). Operator: IT Operations Team.
Limitations	L-01, L-02, group changes not immediate (L-03), OneDrive managed state (L-05).
Validation (D10)	Approved app on BYOD allowed; app outside the policies blocked; noncompliant corporate device of a BYOD user blocked (mandatory, A-01); OneDrive on corporate iOS tested with and without app configuration; each approved app supports the grant (A-04); missing broker redirects to the store; legacy client blocked; group members match

Field	Details
	activation records.
Source	Microsoft Learn: Conditional Access grant; require app protection policy; create and assign app protection policies. Reviewed 3 November 2026.

3.3 Mobile Browser Access Block

Field	Details
Policy	MDM-CAP-003 - All Mobile - Block Browser Access to Microsoft 365
Traceability	D06 Section 4 (Authorized Use); D07 Section 4.1 (MDM-STD-009) and Section 5.10 (MDM-STD-035). D07 Section 5.10 has no D05 control and is covered under known gap 1 in the D10 test plan.
Applies to	All users, including the approved BYOD group, on Android and iOS, for Office 365 in browsers only. Excluded: guest and external users, and emergency access accounts.
Requirement	Block browser access. Approved apps are the only access route.
Design decisions	The block covers every mobile browser, including Edge with App Protection, and a compliant device or App Protection does not override it. Approved apps sign in as mobile apps, not browsers, so they are not affected (A-03). Targeting Office 365 keeps enrollment, Company Portal and security-info registration outside the block.
Rollout and ownership	Starts in report-only; switched on after MDM-CTL-004 approval and pilot results. Owner: IT Operations Manager. Operator: IT Operations Team.
Limitations	A browser in desktop-site mode may appear as macOS and fall outside the policy (L-01).
Validation (D10)	Outlook on the web, SharePoint and OneDrive blocked in mobile browsers on both platforms; approved app sign-in still works; links from Teams and Outlook behave as expected; desktop-site mode tested on iPhone and iPad; enrollment, Company Portal and security-info registration unaffected; in-app web views tested.

Field	Details
Source	Microsoft Learn: Conditional Access conditions, target resources and user targeting; MFA for Intune enrollment. Reviewed 3 November 2026.

3.4 Intune Administrator Phishing-Resistant MFA

Field	Details
Policy	MDM-CAP-004 - Intune Administrators - Require Phishing-Resistant MFA
Traceability	MDM-CTL-005; MDM-RSK-005; D07 Section 5.3 (MDM-STD-028).
Applies to	The MDM-Intune-Admins-* groups and the Intune Administrator and Global Administrator roles, for all resources on any platform. Excluded: emergency access accounts.
Requirement	Phishing-resistant MFA for every account that administers Intune.
Design decisions	Role targeting covers built-in Entra roles only, so the groups that grant Intune roles are also the groups this policy targets; no one can hold an Intune role and be out of scope. Only separately authorized role administrators change these groups (D07 Section 5.2). Enforcing before methods are registered risks lockout. The policy does not allow administration from mobile devices (D06 Section 2).
Rollout and ownership	Starts in report-only; switched on after registration is confirmed and MDM-CTL-004 approval. Recovery: emergency access (Section 4.1) and IAM recovery arrangements (D07 Section 5.3). Owner: CISO (MDM-CTL-005). Operator: enterprise IAM team. IT Operations administrators are in scope but do not configure the policy. Confirm with the IAM owner that no enterprise policy already covers these accounts.
Limitations	Custom or administrative-unit-scoped roles are not covered by role targeting (L-06). Existing sessions (Section 4.2).
Validation (D10)	Phishing-resistant method accepted and weaker methods rejected; Entra-role and Intune RBAC administrators covered (A-05); Graph and PowerShell access covered; group

Field	Details
	members match policy scope; emergency account excluded and monitored; sign-in logs record the authentication strength.
Source	Microsoft Learn: Require phishing-resistant MFA for administrators; Conditional Access grant; filter for devices. Reviewed 3 November 2026.

4. Shared Design Elements

4.1 Emergency Access and Exclusions

Field	Details
Applies To	MDM-CAP-001 to MDM-CAP-004.
Accounts	At least two emergency access accounts, in the MDM-Emergency-Access group.
Account Type	Cloud-only, using the onmicrosoft.com domain. Not synchronized or federated.
Exclusion	Excluded from all four policies.
Authentication	Passkey (FIDO2). The method differs from those used by other administrators.
Monitoring	An alert is raised for every sign-in. Sign-in and audit logs are kept for review.
Validation	Sign-in is tested at least every 90 days and after major policy changes.
Owner	Enterprise IAM team.
Other Exclusions	None beyond those stated in each policy. Any exception follows D06 Section 8.
Exclusion Changes	Follow MDM-CTL-004.

4.2 Session Behavior

Field	Details
Applies To	MDM-CAP-001 to MDM-CAP-004.
Default Token Lifetime	Access tokens last one hour by default.

Field	Details
CAE Sessions	CAE-capable clients may hold tokens for up to 28 hours.
CAE Critical Events	Account disabled or deleted, password reset, sessions revoked, MFA enabled, high user risk.
Supported Services	Exchange Online, SharePoint Online and Teams.
Device Compliance	Microsoft does not list a change in device compliance as a CAE critical event. Access may continue until the token renews (L-02).
Session Revocation	Revoke sessions invalidates refresh tokens. It does not directly end an application's own session.
Policy and Group Changes	Changes to policies or group membership can take up to one day to take effect (L-03).
Departures	Use account disablement and session revocation (D07 Section 5.8). Removal from a group alone is too slow.
Offline Data	Blocking access does not remove data already on the device (L-04). D07 Sections 4.14, 4.15 and 5.9 apply.
Validation (D10)	Measure the time between noncompliance and loss of access. Measure the time between account disablement and loss of access.

4.3 Access Restoration

Field	Details
Corporate Devices	Access returns when Intune reports the device as compliant (MDM-CAP-001).
BYOD	Access returns when the app holds App Protection and passes conditional launch (MDM-CAP-002).
Unverified Status	Missing or unverified compliance is investigated before access is restored (D07 Section 3.6).
Re-enabled Accounts	Expect delays: about 15 minutes for SharePoint and Teams, and 35-40 minutes for Exchange.
Manual Override	Not permitted.

Field	Details
Restoration Evidence	A successful sign-in confirms restoration. A status change alone does not.

4.4 Change and Rollout

Field	Details
Governing Control	MDM-CTL-004.
Initial State	All four policies start in Report-only.
Report-Only Review	Review sign-in logs against expected outcomes before enforcement.
App Protection Note	“Report-only: Failure” for app protection alone is not a pilot failure.
Pilot	Enforce for a pilot group first, then expand in stages.
Approvals	Business Owner, CISO and CAB, before enforcement.
Rollback	Return the policy to Report-only. The previous approved configuration is retained.
Verification Window	Allow up to one day for changes to take effect before final post-implementation checks (L-03).

4.5 Enterprise Dependency: User MFA

Field	Details
Basis	D05 Outstanding Items (Enterprise dependency); D07 Sections 4.6 and 4.11.
Dependency	MFA for user sign-in is provided by an enterprise IAM policy. This project does not design it.
Required Confirmation	The IAM owner identifies the policy and confirms coverage of in-scope users, approved apps, corporate devices and BYOD (A-06).
ADE Enrollment	Phishing-resistant MFA is not supported in iOS/iPadOS Setup Assistant (L-07). Users need another MFA method or a Temporary Access Pass.
Second Device	MFA during ADE needs a second device or a Temporary

Field	Details
	Access Pass.
PIN Recovery	BYOD PIN reset relies on this policy (D07 Section 4.11).
Validation (D10)	Sign-in logs show MFA applied to mobile app sign-ins.
If Not Confirmed	Recorded as a gap in D11.

5. Assumptions and Limitations

The design relies on the assumptions below. Each assumption must be validated in MDM-D10 before the design is treated as effective. Limitations are accepted design boundaries; their handling is stated.

Assumptions

ID	Assumption	Affects	Validation
A-01	On a managed device without App Protection, the app protection grant fails.	MDM-CAP-002	Mandatory D10 test: noncompliant corporate device of a BYOD user is blocked.
A-02	The iOS device platform covers iPadOS.	MDM-CAP-001 to MDM-CAP-003	D10 test on an iPad.
A-03	Approved apps sign in as Mobile apps and desktop clients, not as Browser.	MDM-CAP-003	D10 test of app sign-in and in-app web views.
A-04	The six approved apps support the app protection grant.	MDM-CAP-002	D10 test for each app on both platforms.
A-05	Intune RBAC roles are assigned through Entra groups.	MDM-CAP-004	D09 evidence of role assignments.
A-06	An enterprise user MFA policy exists and covers this scope.	Section 4.5	Confirmation from the IAM owner; D10 sign-in log review.

Limitations

ID	Limitation	Affects	Handling
L-01	Device platform relies on the user agent, which can be changed. A browser in	MDM-CAP-001	Enterprise desktop policies provide protection. D10

ID	Limitation	Affects	Handling
	desktop-site mode may appear as macOS.	to MDM-CAP-003	tests desktop-site mode.
L-02	A change in device compliance is not a CAE critical event. Access may continue until the token renews.	MDM-CAP-001, MDM-CAP-002	Carried to D11 and D12 under MDM-RSK-003.
L-03	Policy and group changes can take up to one day to take effect.	All policies	Section 4.4 verification window. Departures use D07 Section 5.8.
L-04	Blocking access does not remove data already on the device.	All policies	D07 Sections 4.14, 4.15 and 5.9.
L-05	OneDrive on corporate iOS needs manual app configuration. Without it, the device is treated as unmanaged.	MDM-CAP-002	Section 2.3 prerequisite. D10 tests OneDrive with and without configuration.
L-06	Role targeting does not cover custom or administrative-unit-scoped roles.	MDM-CAP-004	Policy targets the Intune RBAC groups.
L-07	Phishing-resistant MFA is not supported in iOS/iPadOS Setup Assistant.	Section 4.5	Another MFA method or a Temporary Access Pass for ADE enrollment.
L-08	No tenant was configured. Report-only results cannot be observed.	All policies	D09 and D10 are marked as simulated.

6. Sources

All Microsoft Learn pages were reviewed on 3 November 2026.

Source	Used In
Microsoft Learn: Conditional Access: Grant - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-grant	3.1, 3.2, 3.4
Microsoft Learn: Migrate approved client app to application protection policy in Conditional Access - https://learn.microsoft.com/en-us/entra/identity/conditional-access/migrate-approved-client-app	3.2
Microsoft Learn: Require approved app or app protection policy -	3.2, 4.4

Source	Used In
https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-all-users-approved-app-or-app-protection	
Microsoft Learn: Conditional Access: Conditions - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-conditions	3.1, 3.3, 5
Microsoft Learn: Conditional Access: Target resources - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-cloud-apps	3.3
Microsoft Learn: Conditional Access: Users, groups, and workload identities - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-users-groups	2.1, 3.1, 3.3
Microsoft Learn: Conditional Access: Filter for devices - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-condition-filters-for-devices	3.4
Microsoft Learn: Require device compliance with Conditional Access - https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-all-users-device-compliance	3.1
Microsoft Learn: Require phishing-resistant multifactor authentication for administrators - https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-admin-phish-resistant-mfa	3.4
Microsoft Learn: Continuous access evaluation - https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-continuous-access-evaluation	4.2, 4.3
Microsoft Learn: Revoke user access in Microsoft Entra ID - https://learn.microsoft.com/en-us/entra/identity/users/users-revoke-access	4.2
Microsoft Learn: Manage emergency access accounts in Microsoft Entra ID - https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/security-emergency-access	4.1
Microsoft Learn: How to create and assign app protection policies - https://learn.microsoft.com/en-us/mem/intune/apps/app-protection-policies	2.3, 3.2

Source	Used In
Microsoft Learn: Set up multifactor authentication for Intune device enrollment - https://learn.microsoft.com/en-us/mem/intune/enrollment/multi-factor-authentication	3.3, 4.5
Microsoft Learn: Authentication methods for automated device enrollment - https://learn.microsoft.com/en-us/intune/device-enrollment/apple/ref-automated-authentication-methods	4.5